

Table of Contents

Cisco Secure Workload — HITRUST CSF v11

Reference Design | Certifiable Security & Privacy Programs

Version: 1.0

Use Case: Fresh Install, Hybrid Environment (On-Prem + Cloud)

Framework Reference: HITRUST CSF v11 (MyCSF / assessed programs)

Reader's Guide

Who this is for. Organisations pursuing **HITRUST certification or re-certification** (healthcare, payer, SaaS, business associates) and security architects implementing **assessment level** obligations across harmonised controls drawn from **HIPAA, ISO 27001, NIST SP 800-53, PCI DSS**, and related sources.

Questions this reference design helps you answer:

- *How do I demonstrate **continuous technical enforcement** for network segregation and connection control—not only annual policy PDFs? (01.m, 01.n, 01.o)*
- *What machine-generated evidence supports **monitoring of system use and administrator / operator traceability** between assessments? (09.ab, 09.ad)*
- *How does **ADM** help with **security requirements analysis** and dependency mapping during design changes or M&A integrations? (10.a)*
- *Where do **CVE awareness + reachability** strengthen **control of technical vulnerabilities** between scans and patch cycles? (10.m)*
- *What forensic-ready exports support **reporting information security events and collection of evidence** during incidents? (11.a, 11.c)*

What you'll need. Your **HITRUST scope** (systems, facilities, cloud), the **selected assessment levels** (e.g., e1, i1, r2) for in-scope requirements, PRS/statement mappings from your assessor or MyCSF export, and **cross-walks** to any organization-specific control IDs.

Where to start. Sections 1–2 for framing; 3–6 for deployment; 7 for **requirement-level** mapping to CSW; 8 for boundaries; 9–10 for evidence; Appendix A for **assessment levels**; Appendix B for **cross-framework** reference design pointers.

CSW primer — if you are new to Cisco Secure Workload

Cisco Secure Workload (CSW) is a **workload protection platform**. A lightweight **agent** on each server/VM/container observes processes and network flows; **cloud connectors** add AWS/Azure/GCP inventory where agents are not deployed.

CSW term	Meaning	Why compliance teams care
Scope	Logical boundary (CDE, PHI zone, CUI enclave)	Defines the systems you must prove are isolated
Label / filter	Tag or query assigning workloads to scopes	Automates scope membership — reduces drift
ADM	Application Dependency Mapping from observed traffic	Live network/data-flow diagram for assessors
Workspace	Policy container for one scope or application	Where allow/deny rules are authored
Monitor → Simulation → Enforce	Safe rollout sequence	Simulation = change-board evidence before blocking traffic
Denied Connections	Log of flows blocked by policy	Primary proof that enforcement operates

Console areas: Investigate (inventory, flows, vulns) · Defend/Segmentation (policy) · Manage (agents) · Platform (connectors) · Administration (audit log)

Read next: [Compliance evidence playbook](#) (full step-by-step) · [About CSW](#) (platform intro)

Universal evidence workflow

Execute these phases for **this framework's** compliance boundary. Map exports to control IDs in the **Reporting & Evidence** section below.

Phase	Goal	Key CSW actions	Typical duration
1 — Coverage	Every in-scope workload in CSW	Install agents/connectors ; apply compliance labels; create scope	Days 1–10
2 — Baseline	Machine-generated flow map	Run ADM ≥2 weeks; export clusters; app-	Days 11–28

Phase	Goal	Key CSW actions	Typical duration
		owner signoff	
3 — Policy	Designed isolation before enforce	Build workspace; Simulation mode; fix false positives	Days 29–45
4 — Operate	Continuous proof between audits	Enforce; quarterly export pack; ADM refresh every 90 days	Ongoing

Phase 1 checklist (coverage)

- ☐ In-scope host list reconciled to CSW Inventory (100% or documented exceptions)
- ☐ Labels applied: `compliance:<framework>`, `data:<classification>`, `env:<tier>`
- ☐ CSW scope created matching compliance boundary
- ☐ **Export:** inventory CSV + agent status screenshot

Phase 2 checklist (baseline)

- ☐ ADM running on compliance scope for full business cycle (≥ 2 weeks)
- ☐ Unexpected flows documented (shadow IT, vendor egress, scope creep)
- ☐ App owners signed cluster-to-application mapping
- ☐ **Export:** ADM diagram + flow samples with process context

Phase 3 checklist (policy)

- ☐ Default-deny posture defined for sensitive scope
- ☐ ADM-imported rules refined; Simulation run ≥ 1 week
- ☐ Change tickets for false-positive fixes; exception register updated
- ☐ **Export:** policy export + simulation report

Phase 4 checklist (operate)

- ☐ Enforcement enabled on pilot scope; negative test recorded in Denied Connections
- ☐ Quarterly pack: inventory, policy, denies, vulns, audit log (see playbook)
- ☐ SIEM integration verified (sample events)
- ☐ **Export:** enforcement screenshot + quarterly binder

What CSW evidence does not replace

Physical access, HR/training records, encryption key management, signed BAAs/vendor contracts, formal pen tests, and assessor attestation still require separate programmes. CSW addresses the **workload-resident** slice: segmentation, flows, process context, vuln reachability, and change drift.

CSW effectiveness for this framework

- Harmonized HIPAA+ISO+NIST+PCI evidence in one scope model
- e1/i1/r2 assessment level guidance
- Single workload evidence source for multiple inherited controls

Compared to manual programmes: static diagrams and annual firewall samples age immediately; CSW ties evidence to **live workload behaviour** and produces queryable exports on demand — supporting "operating effectively" language in PCI v4.0, SOC 2 CC7, and HIPAA risk analysis.

1. Overview

HITRUST CSF v11 is a **certifiable** control framework that **harmonises** multiple regulatory and standards baselines. CSW contributes **technical and operational evidence** where controls expect **network segregation, connection control, continuous monitoring of workloads, vulnerability context, and forensic visibility**—without replacing governance, risk analysis, privacy programme elements, or assessor judgement.

1.1 HITRUST Harmonisation Context

Harmonised Baseline (Examples)	Role in Typical HITRUST Engagement
HIPAA Security Rule	Healthcare privacy/security posture
ISO/IEC 27001 / 27002	ISMS-aligned management system evidence
NIST SP 800-53	Control depth for federal-style rigour
PCI DSS	Payment environments inside hybrid scope
NIST CSF / others (per your factor analysis)	Risk program alignment

Cross-reference: This repo includes dedicated CSW reference designs for [HIPAA](#), [ISO/IEC 27001:2022](#), [NIST SP 800-53](#), and [PCI DSS v4.0](#). Use them when your HITRUST statement explicitly cites those underlying requirements.

1.2 HITRUST Domain Themes → CSW Capabilities (Summary)

CSF Domain Theme (Illustrative)	Representative Topics	Relevant CSW Capabilities
01 — Network / connectivity	Segregation, connection & routing control	Microsegmentation, policy enforcement, flow visibility
06 — Data management	Protection, handling mapping	Data-flow mapping (technical), isolation

CSF Domain Theme (Illustrative)	Representative Topics	Relevant CSW Capabilities
		enforcement
09 — Monitoring & logging	System use, privileged activity evidence	Continuous monitoring, process telemetry, exports
10 — Vulnerability / change	Requirements analysis, technical vulnerability mgmt	ADM, CVE + reachability, drift signals
11 — Incident mgmt	Reporting, evidence handling	Forensic timelines, snapshots, integrations

Notation: Requirement identifiers such as **01.m** follow common HITRUST short-form references used in assessment discussions. **Confirm exact PRS text and keys** in your MyCSF/MyCSF export—HITRUST wording evolves by release and factor analysis.

2. Pre-Deployment Checklist

- ☐ **HITRUST scope** document current (systems, sites, cloud accounts, outsourced functions)
- ☐ **Assessment levels** selected per requirement (e.g., e1 / i1 / r2—see Appendix A) and agreed with assessor
- ☐ **Data classification** map available for in-scope workloads
- ☐ CSW cluster online; connectivity from workloads (typically **443 outbound**)
- ☐ Sensor support matrix validated for all **in-scope OSes / containers** (per vendor guidance)
- ☐ Cloud connectors (AWS/Azure/GCP) configured if workloads are IaaS/PaaS
- ☐ Stakeholders: Risk owner, ISO, SOC/IR, GRC tooling admin, platform owners
- ☐ Change approvals for **monitoring-first** deployment (no Day-1 enforcement)

3. Phase 1 — Sensor Deployment (Days 1–7)

3.1 Standard Agent Deployment (Linux Example)

RHEL/CentOS family

```
sudo rpm -ivh tet-sensor-<version>.rpm
```

Debian/Ubuntu

```
sudo dpkg -i tet-sensor-<version>.deb
```

Health check (service name may vary by packaging)

```
systemctl status csw-agent || systemctl status tetration-agent
```

Day-1 posture

Control	Value
Enforcement	Off / Monitoring
Labels	compliance:hitrust, hitrust-scope:in
Collection	Flow + process (+ vulnerability where licensed)

3.2 Cloud / Agentless Augmentation

CSW UI → Platform → External Orchestrators

- Connect cloud accounts (least privilege)
- Enable flow telemetry pathways (e.g., VPC/VNet flow logs) where used

3.3 Coverage Validation

CSW UI → Manage → Agents

- Filter labels: hitrust-scope=in
- Confirm 100% of production in-scope instances ****active**** (target)

Evidence: Screenshot or API export of agent inventory + version compliance.

4. Phase 2 — Scope & Segmentation Design (Days 5–14)

4.1 Scope Hierarchy (Example)

Root Scope

```

└─ HITRUST-In-Scope
    └─ PHI-Production (if healthcare data present)
    └─ PCI-CDE-Connected (if card data adjacent)
    └─ Enterprise-Critical (shared services – justify narrowing)
    └─ Sandboxed-DevTest (usually policy-parity, non-prod evidence optional)

```

Align scopes to **risk tiers** in your HITRUST **risk analysis** record.

4.2 Labels for Assessment Traceability

Label	Purpose
hitrust-scope	in out dual
data-class	phi pii confidential public
tier	critical high medium
owner	team accountable for control operation

5. Phase 3 — Visibility, Baseline & ADM (Days 7–35)

5.1 Application Dependency Mapping (10.a — Security Requirements Analysis)

CSW **ADM** validates **as-designed vs as-observed** connectivity—critical when HITRUST expects evidence of **security requirements analysis** during architecture changes.

CSW UI → Investigate → Application Dependency Mapping

- Workspace: "HITRUST-ADM-Baseline"
- Scope: HITRUST-In-Scope (start broad; refine)
- Window: ≥2–4 weeks
- Enable process context; user context where supported

Workflow

1. Export cluster + edge inventory.
2. Compare to **approved connection matrix / data-flow diagrams**.
3. File **exceptions** or **change records** for every undocumented path.
4. Promote refined scopes and policy candidates.

5.2 Network Segregation Visibility (01.m / 01.n / 01.o)

Requirement	CSW Angle	Evidence
01.m Segregation in networks	Workload-level segmentation ; deny lateral movement by default in-policy	Policy exports; ADM before/after
01.n Network connection control	Allowlists tied to apps/services; deny/residual logging	Enforcement + violation stats
01.o Network routing control	Observed routing outcomes via flows (what actually connected, on which ports)	Flow searches; path over time

Assessment level nuance: Higher **i1/r2** rigour often expects **ongoing** validation artifacts, not a one-time screenshot—schedule quarterly ADM refresh.

6. Phase 4 — Policy Design, Enforcement & Monitoring (Days 25–60)

6.1 Policy Workspace

CSW UI → Defend → Segmentation

- Workspace: "HITRUST-Technical-Enforcement"
- Import ADM rules → shrink to ****authorised**** edges only
- Simulation → phased enforcement

6.2 Illustrative Policy Snippets (Logical)

Segregation baseline (default deny between tiers):

```
rules:
- name: Deny-High-to-PHI-Lateral
  action: DENY
  source:
    labels: { tier: medium }
  destination:
    labels: { data-class: phi }
```

Connection control (service allowlist):

```
rules:
- name: Allow-Approved-Web-To-API
  action: ALLOW
  source:
    labels: { app-tier: web }
  destination:
    labels: { app-tier: api }
  services:
    - protocol: TCP
      ports: [443]
```

Monitoring-first alert on novel dependency:

```
rules:
- name: Log-New-EastWest-Unapproved
  action: ALERT
  source:
    scope: HITRUST-In-Scope
  destination:
    scope: HITRUST-In-Scope
  match: not_in_adm_baseline: true
```

7. Phase 5 — Control-by-Control Mapping (CSF v11 Statements — Key User References)

Replace bracketed notes with your **exact PRS identifiers** from MyCSF. **Assessment columns** show how rigour typically **ramps** from **e1** → **i1** → **r2** for technical evidence depth (see Appendix A).

HITRUST Ref	Statement Theme (Short)	CSW Capability	Evidence Produced	Typical Level Expectation*
01.m	Segregation in networks	Microsegmentation (allowlist/den	Policy exports; ADM diffs;	e1: design + samples; i1/r2:

HITRUST Ref	Statement Theme (Short)	CSW Capability	Evidence Produced	Typical Level Expectation*
		y between labels/scopes) ; ADM proves intended isolation	violation reports	recurring automated exports, drift detection
01.n	Network connection control	Enforcement of authorised services/ports ; logging of denials	Enforcement mode history; connection control dashboards	i1/r2: stronger continuous proof
01.o	Network routing control	Flow-based visibility of effective paths; multi-hop context via telemetry	Time-bounded flow searches; top-talkers & new edges	r2: often pairs with formal residual risk treatment
06.d	Data protection & privacy (technical facets)	Data-flow mapping at workload layer; isolation between classes	Flow maps tagged by data-class ; segregation policies	Pair with privacy artifacts (RoPA, DPIA) external to CSW
09.ab	Monitoring system use	Continuous monitoring of flows/processes; anomaly detection	24×7 monitoring exports; alert routing to SOC	Integrate with SIEM narrative
09.ad	Administrator & operator logs	Process + identity context on admin tooling paths; forensics exports	Admin-path flow bundles; operator session timelines	Correlate with IdP / privileged access logs
10.a	Security requirements analysis	ADM + change reviews for requirements	Before/after ADM on change tickets;	Strong fit for design-stage evidence

HITRUST Ref	Statement Theme (Short)	CSW Capability	Evidence Produced	Typical Level Expectation*
		validation	architecture review pack	
10.m	Control of technical vulnerabilities	CVE visibility + reachability; policy compensations	Scoped vulnerability reports; exposure ranked by workload criticality	Combine with patch SLAs
11.a	Reporting information security events	Incident evidence: flows/processes for IOC timeboxes	IR exports + ticketing references	CSW supports evidence , not IR governance alone
11.c	Collection of evidence	Forensic snapshots (flows/process/policy versions)	Signed export packages; hash manifests	Chain-of-custody alignment

* **Typical expectation** varies by **assessor interpretation**, **organizational risk**, and **selected factors**—treat this column as planning guidance, not a guarantee.

7.1 HITRUST ↔ Source Framework Cross-Walk (Where Overlapping PRS Exist)

When your MyCSF mapping cites an underlying clause, consult the matching repo reference design **in addition** to this document:

If your PRS traces to...	See Also
HIPAA Security Rule technical/administrative themes	HIPAA
ISO 27001 Annex A (network logging, segregation)	ISO 27001
NIST 800-53 AC/SC/AU/SI families	NIST 800-53
PCI DSS Req 1/10/11-style evidence	PCI DSS v4

8. Boundaries — What CSW Does **Not** Cover

Topic	Boundary
HITRUST certification decision	Only HITRUST / external assessors

Topic	Boundary
Policy & programme documents	certify; CSW supplies artifacts. Policies, standards, SoA, risk register narratives remain GRC tasks.
Privacy-specific legal controls	DPIA, lawful basis, consent, BAAs/DPA execution—legal/privacy teams.
Cryptographic implementations	Algorithm selection, key ceremony, HSM governance—outside CSW.
Endpoint AV / EDR	CSW complements but does not replace traditional malware controls.
Vulnerability scanning tools	CSW contextualises exposure; authenticated scans may still be required.
Physical security	Facilities, badges, cameras—out of scope.

9. Audit Preparation & Evidence Export

9.1 HITRUST-Friendly Evidence Catalogue (Technical)

Evidence	CSW Source	Useful For (Examples)
Inventory & label posture	Manage → Inventory	01.m / baseline scoping
Segmentation policy + versions	Defend → Segmentation	01.m / 01.n
ADM reports (time-stamped)	Investigate → ADM	01.o / 10.a
Flow exports (samples + population stats)	Flow Search	06.d / 09.ab
Process / admin path exports	Process Search	09.ad
Vulnerability + reachability	Vulnerability views	10.m
Alert history & SOC tickets	Alerts / integrations	11.a
Forensic bundles	Combined export + hashes	11.c

9.2 Bash / Packaging Example

```
#!/usr/bin/env bash
set -euo pipefail
```

```

CYCLE="2026-05-HITRUST"
OUT="hitrust_tech_evidence_${CYCLE}"
mkdir -p "${OUT}"

# Replace with supported CSW automation:
# csw inventory export --labels hitrust-scope=in >
"${OUT}/inventory.json"
# csw policy export --workspace HITRUST-Technical-Enforcement > "${OUT}/policy.json"
# csw adm export --workspace HITRUST-ADM-Baseline >
"${OUT}/adm_edges.csv"

(
  cd "${OUT}"
  find . -type f -print0 | sort -z | xargs -0 sha256sum
) > "${OUT}/SHA256SUMS.txt"

echo "Transmit ${OUT} via approved secure file transfer; retain manifest."

```

9.3 SIEM & Ticketing Integration

- Forward **alerts** and **high-signal logs** using CSW-supported integrations (Splunk, QRadar, Sentinel, Chronicle, etc.—per deployment).
 - Always store **correlation IDs** linking SIEM events ↔ CSW investigation UUIDs.
-

10. Vulnerability & Compensating Controls (10.m Depth)

CSW UI → Investigate → Vulnerability Report

- Scope: HITRUST-In-Scope + tier=critical
- Sort: Reachable from untrusted labels first
- Export for risk committee review

Compensating pattern (illustrative):

```

rules:
- name: Compensate-Critical-CVE-442-limit-peers
  action: ALLOW
  source:
    labels: { app-tier: trusted-integrators }
  destination:
    hosts: [db-prod-01]
  services:
    - protocol: TCP
      ports: [5432]

```

Document **time-bound** compensations with **owners** and **expiry** in your HITRUST risk register.

11. Common Pitfalls

Pitfall	Mitigation
Treating ADM once as perpetual truth	Quarterly or change-triggered reruns
Over-segmenting shared services	Design narrow broker roles; avoid brittle allowlists
Confusing network diagrams with observed flows	Lead assessors with ADM + flows side-by-side
Missing container inventory	Deploy supported visibility for orchestrated workloads
Weak change record linkage	Tie tickets → policy version bumps

Appendix A — Assessment Levels (e1, i1, r2)

HITRUST engagements commonly frame **progressive assurance** across requirements. **Exact definitions** are contractually specified in HITRUST methodology and your **MyCSF** program settings. **Practical technical interpretation** for CSW evidence:

Level	Short Label (Colloquial)	How CSW Evidence Usually Shows Up
e1	Established baseline	Policies + sample exports showing controls exist; point-in-time inventory
i1	Implemented with ongoing operation	Scheduled exports, dashboards, alert routing proofs; months of history
r2	Risk-based maturity depth	Continuous drift detection, robust exception handling, trend metrics, integration with enterprise GRC

Always validate level selection with your **HITRUST assessor**—programs vary by **industry factor analysis** and **relief** choices.

Appendix B — Cross-Reference Index to Repo Reference designs

Framework	Path
HIPAA	../HIPAA/CSW-HIPAA-Reference-Design.md

Framework	Path
ISO/IEC 27001:2022	../ISO-27001-2022/CSW-ISO27001-Reference-Design.md
NIST SP 800-53	../NIST-800-53/CSW-NIST-800-53-Reference-Design.md
PCI DSS v4.0	../PCI-DSS-v4/CSW-PCI-DSS-Reference-Design.md

Document prepared for Cisco healthcare & regulated SaaS engagements. Replace [Customer Name] and organization-specific identifiers before customer delivery.